DFIR-Rapid: Capstone II Feature Strategy

Oct 11, 2026 · @Tofu

1. Summary

DFIR-Rapid should compete on access, not depth: a fixed-price, pre-agreed forensic service that Cambodian and ASEAN SMEs can activate in minutes. Enterprise firms already serve large clients; the gap sits below them.

- **Positioning:** affordable, transparent, locally aware DFIR for SMEs with 10 to 200 staff (e-commerce, fintech, SaaS, NGOs).
- **Build first:** five core features (section 3), then four differentiators (section 4).
- **Demo scope (recommended):** a Windows endpoint, which covers disk forensics, plus one cloud platform (M365, Google Workspace or AWS). Mobile is deferred.
- **Basis:** research on Mandiant, CrowdStrike, Unit 42 and Blackpanda, plus team discussion. Points that are team judgment rather than sourced are marked.

2. Benchmark: what the leaders do

Three enterprise firms lead on depth and brand, but none publishes pricing and none of the pages reviewed lists Cambodia, which leaves room for an SME-first service. Forrester's Q2 2024 Wave on incident response named CrowdStrike, Google (Mandiant) and Palo Alto Networks among its Leaders.

Firm	What they offer	Why customers choose them	Gap for ASEAN SMEs
Mandiant (Google Cloud)	Annual retainer, 24x7 access, 2-hour response, prepaid hours that can be repurposed to assessments, tabletops and training	Frontline reputation; recognized as an IR leader by Forrester and IDC	Pricing not public; built for enterprise scale

Firm	What they offer	Why customers choose them	Gap for ASEAN SMEs
CrowdStrike Services	Retainer with selectable response time; more committed hours lower the hourly rate; unused hours go to proactive work	Strong threat intelligence and Falcon telemetry; Gartner Peer Insights 4.8 from 58 ratings	SME reach is mainly through partners and MSSPs; pricing not public
Palo Alto Unit 42	Prepaid credits in four tiers (250, 550, 1,250, 2,500+) with 24h, 8h, 4h and 2h remote response; credit portal with usage history	Approved by 70+ cyber insurers; partner to 150+ law firms	Free IR retainer is for qualified Palo Alto customers only; the free retainer's on-site SLA excludes Southeast Asia
Blackpanda (APAC reference)	Fixed-cost IR subscription, self-service client portal, collection tools shipped in advance, insurance bundle in Japan	Speed, fixed cost, local-language teams in Japan, Singapore, Hong Kong and the Philippines	No Cambodia team listed

Team read of the gap (judgment, not sourced): a transparent entry price, Khmer-aware delivery, and a vendor-neutral open-source toolset. Desk research found no verbatim customer complaints, so interviews with local SMEs should validate this (section 8).

3. Core build (priority)

Build these five first; together they cover the NDA, SLA, payment, dashboard, tracking, check-up and reporting items already on the list.

#	Feature	What it does	Demo evidence
1	Zero-friction activation	NDA, SLA and payment terms are e-signed at onboarding, so a one-click "Report Incident" button starts a case with no paperwork during the crisis	Signed onboarding record; new case opens with SLA timer running
2	Pre-packaged collection kit	A signed, read-only script gathers triage artifacts (event logs, memory, key files), hashes them automatically and prepares Chainsaw output	Hash manifest plus Chainsaw detections
3	Credits dashboard	One prepaid balance covers monthly check-ups, add-ons and incident hours, with usage history and an old/new client flag	Ledger view showing deductions per activity
4	Onboarding readiness assessment	A questionnaire on controls and environment sets the client's tier and feeds the profile and monthly check-up	Completed questionnaire mapped to a tier
5	Automated report and Gantt-style timeline	Hashes, attack timeline, IOCs and impact flow into the Unified Forensic Report; milestones follow the five-step investigation flow	Generated report with timeline and evidence list

4. Differentiators

Four features that are cheap to build and set DFIR-Rapid apart for the local market.

Feature	What it does	Note
Compromise assessment as entry product	A fixed-price "are we already breached?" sweep that wins new clients	The three major firms each sell a version
Local compliance reporting	Report template mapped to NBC breach-reporting rules, with a Khmer summary	None of the firms researched list Cambodia, but this is not proven; lawyer review needed
Tier-based SLA clock	Live countdown on the case dashboard, with response time tied to tier	Unit 42 ties response time to tier, 24h down to 2h
Insurer-ready report format	Evidence summary formatted to what insurance claims need	No insurer panel agreements in the capstone; this is the first step toward one

5. Optional add-ons (quality of life)

These are team judgment, loosely based on extras the larger firms sell. The first three are the recommended priority.

Add-on	What the customer gets	Effort
1. Log readiness setup	Audit logging turned on and extended (M365, Google, Windows) so evidence exists before an incident	Low
2. Post-incident re-check	A scan 30 days after closure, with a short "all clear" letter	Medium
3. Notification and comms pack	Draft notices for regulators, customers and staff in Khmer and English, as fill-in-the-blank templates	Medium (needs legal review)
Insurance and cost pack	Evidence summary plus a cost-tracking sheet for claims	Low
Cost-of-incident calculator	A web page where owners estimate loss; doubles as a lead magnet	Low

Add-on	What the customer gets	Effort
Messenger or Telegram intake	Report an incident from chat, since Facebook dominates in Cambodia	Medium
Phishing simulation	Monthly test emails (GoPhish) with results in the check-up report	Medium
Leaked-credential alerts	Notice when staff emails appear in breach dumps; check each source's terms	Medium

Avoid: ransomware negotiation or payment handling. It carries legal and safety risk, and the SLA already excludes legal certification. The comms pack is drafts only, with no promise of legal compliance.

6. Operations and legal foundations

Collecting evidence from a client's systems needs explicit permission, a secure path for the data, and a plan for security tools that will react to our collector.

Walk-in clients (no prior onboarding)

- Short intake form or hotline captures the incident and the caller's identity.
- One combined e-signature covers the NDA, engagement terms and authorization to access systems, with an approval workflow.
- Payment is a deposit or prepayment at the emergency (burst) rate.
- While paperwork finishes, the team gives containment guidance: isolate machines, do not reboot or wipe.
- Afterward, the readiness assessment and a subscription offer convert the client.
- Proposed: the SLA clock starts once authorization and deposit are complete (see section 7).

NDA checklist

- Explicit scope: what we are working on.
- Mutual or unilateral structure.
- Applicable privacy law.
- Chain of custody and secure channel.

- Remedies for breach.
- Duration.

Forensic-specific authorization

- Named authorized person and written approval, listing the systems in scope.
- Data processing agreement: what we collect, where it is stored, retention period.
- Staff notice, so employees know their devices may be examined.
- Cross-border transfer may require legal checks, particularly for fintech under NBC rules; a lawyer should confirm.

Collection and secure channel

- **Cloud accounts (M365, Google, AWS):** no agent needed; the client creates a read-only role and logs are pulled through the provider's API.
- **Endpoints:** a signed collector, allowlisted by the client's IT, because DLP or EDR tools may flag it. Notify their SOC; never disable their security tools without written approval.
- Data is encrypted and hashed on the host, uploaded to per-case encrypted storage, and hash-verified on receipt.
- Analysis runs in an isolated workspace; deletion is certified at case closure.

Evidence analysis versus malware detonation

Evidence analysis examines static data left on a system. Malware detonation runs a suspicious file in a controlled environment to watch how it behaves. Look up file hashes first, and use a private or self-hosted sandbox for confidential samples rather than public upload services.

7. Open decisions and risks

Six points need a team decision before Capstone II scope is fixed; items 1, 2, 4 and 5 are inconsistencies in the current Capstone I document.

#	Decision	Issue	Suggested direction
1	Service scope	Section 4.2.9 excludes 24/7 monitoring, but the business model lists 24/7 alerting and MDR in higher tiers	Forensics only (retainer plus monthly check-up) for the capstone
2	"Court-ready" wording	The UVP says court-ready, while the liability clause says findings are not court-admissible	Reword to "evidence handling aligned with ISO/IEC 27037"
3	Walk-in SLA start	Walk-ins have no pre-signed terms	Start the clock when authorization and deposit complete
4	UVP figures	"60% faster, 75% cheaper" has no cited source	Source or soften before submission
5	Pricing consistency	Executive summary quotes $200 to $500 monthly and $800 to $1,500 per incident; section 7 shows tiers of $500 to $5,000 and $1,500 per incident	Align all sections to one price table
6	Legal review	NDA, DPA, comms templates and cross-border transfer	Have a lawyer review once before launch

Key risks: security tools (DLP, EDR) flagging the collector; privacy exposure from over-collection; evidence already damaged in walk-in cases, handled by the existing best-effort clause.

8. Next steps

- [ ] Confirm the demo scope (Windows endpoint plus one cloud platform) and the five core features
- [ ] Resolve the open decisions in section 7
- [ ] Draft the onboarding bundle: NDA, SLA, payment terms and system authorization
- [ ] Build the collection kit and the report template

- [ ] Interview 5 to 10 Cambodian SMEs or MSPs to validate the market gaps
- [ ] Draw the architecture diagram for Appendix A

Sources

Vendor pages and analyst summaries as of October 2026. Forrester and IDC findings are taken from vendor announcements, not from the full reports.

- Mandiant Retainer
- Unit 42 Retainer datasheet
- Gartner Peer Insights: CrowdStrike DFIR retainer
- Frost & Sullivan: Blackpanda write-up
- CrowdStrike: 2024 Forrester Wave announcement
- Google Cloud: Forrester Wave announcement
- Palo Alto Networks: Unit 42 Forrester announcement